Lab 07: Read an HTTP Exchange

A scope-first bug-bounty learning exercise using browser tools and an authorised training page

Objective

Learn to describe an HTTP request and response clearly. This exercise builds the observation and note-taking skills used before any vulnerability claim: method, path, status code, response type, and relevant security controls.

PRACTICE BOUNDARY Use PortSwigger Web Security Academy's intended lab or a local, isolated OWASP Juice Shop instance. Do not test unrelated public websites, try other users' accounts, or run scanners for this exercise.

Step 1 - Set up a safe observation

1. Open a training page you are explicitly allowed to use and read the lab instructions first.
2. Open your browser developer tools and select the Network panel.
3. Reload the training page and select an ordinary request generated by your own browser.
4. Record the method, path, status code, content type, and whether the response was expected. Do not copy session cookies, tokens, or personal data into your notes.

Step 2 - Read status codes in context

Code family / example	Friendly explanation	Careful interpretation
200 OK	The server completed the request.	Does not prove the response was secure or appropriate.
301 / 302	The server redirects the browser.	A redirect may be expected. Read the destination within the lab scope.
401 / 403	Authentication or permission is required or denied.	Do not try to bypass it on a real system. In a lab, follow the provided instructions.
404 Not Found	The requested route or resource was not found.	A 404 is not automatically a vulnerability.

Step 3 - Make a safe observation note

Field	Example / what to record
Environment	Name of the official training lab or local app.
Request	GET /profile (training page); remove tokens and secrets.
Status	200 OK; note whether that matches the intended behaviour.

Field	Example / what to record
Response metadata	Content-Type and other relevant non-secret headers.
Expected vs observed	What did the lab say should happen, and what actually happened?
Conclusion	Observation only, a confirmed lab issue, or inconclusive. Explain why.

Step 4 - Understand common header concepts

- Secure cookie attribute: tells browsers to send the cookie only over secure HTTPS connections.
- HttpOnly cookie attribute: prevents client-side scripts from reading the cookie through standard browser APIs.
- SameSite cookie attribute: helps control when browsers attach cookies to cross-site requests.
- Content-Security-Policy: a browser-enforced policy that can reduce the impact of some content-injection problems.
- A missing or unusual header is a clue to review in context, not automatically a reportable vulnerability.

Step 5 - Finish the worksheet

Use labs/bug-bounty-http-observation-worksheet.csv. Record only the training environment and non-sensitive evidence. If you identify a possible issue, confirm that the lab expects you to test it and write down the expected behaviour, observed behaviour, minimal reproduction, impact, and a defensive fix.

Further learning

- PortSwigger Web Security Academy
- OWASP Web Security Testing Guide
- OWASP Juice Shop

STOP IF UNCLEAR If the target is not a designated training environment or written scope is unclear, stop. The exercise is about observation and reporting, not obtaining access.